

AI-NATIVE CARE ROUTING

Security and Compliance Packet

For insurers, healthcare facilities, pilot partners, investors, and security reviewers.

Current status

HIPAA-aware readiness document. Not SOC 2, ISO 27001, or HIPAA certification. Formal review is required before production PHI deployment with covered entities.

Executive Summary

Carevo is an AI care-routing platform for health insurers and healthcare facilities. The patient-facing product asks focused symptom questions, checks emergency signals first, and routes people toward emergency services, ER, urgent care, primary care, telehealth, or home care. Carevo AuditOS is the enterprise monitoring layer for route safety, consent state, decision traces, audit readiness, and cost operations.

Carevo is designed so the language model does not choose the care level. The model helps extract structured facts and phrase plain-language questions. The final care route comes from a deterministic rules engine with emergency-first safety floors, replayable provenance, and release gates that treat under-triage as blocking.

Area	Current posture	Status
HIPAA	HIPAA-aware architecture and privacy copy are in place. Formal production posture requires BAAs, policies, risk analysis, and operational controls.	Readiness, not certified
SOC 2	Control documentation has started, but no CPA audit has been completed.	Future Type I/II
ISO 27001	Useful later for international enterprise diligence, but not the first startup compliance spend.	Future
AI safety	LLM extracts and phrases only; deterministic engine routes.	Implemented

Product and Data Flow

Step	What happens	Compliance relevance
1. Patient message	User enters symptom text; no account, name, member ID, address, or record number is required.	Minimizes unnecessary data collection.
2. Emergency net	Deterministic emergency and self-harm checks run before ordinary AI processing.	Safety-first design.
3. AI extraction	Model converts text into structured routing facts.	Model does not choose care level.
4. Deterministic route	Rules engine applies safety floors and matched rules.	Auditable, replayable route logic.
5. Optional sharing	User can consent to share the conversation for quality review and receives a deletion code.	Consent and erasure workflow.
6. AuditOS	Enterprise view displays route, consent state, rules, questions, and metrics.	Operational monitoring.

Data Categories

Data type	Used for	Storage posture
Symptom text	Intake and fact extraction	Local/session flow unless user opts into research sharing.
Routing facts	Route logic and audit trace	Decision audit records.
Location or ZIP	Facility lookup and cost context	Forwarded for lookup; not intended as durable profile data.
Consent-shared conversation	Quality review	Access-controlled log/KV when configured; deletion code issued.
API keys	Server services	Server-side environment variables only.

Security Controls Implemented

Control	Current implementation
Transport security	Vercel-managed TLS with HSTS configured.
Browser headers	CSP, frame denial except same-origin embed, MIME protection, referrer policy, permissions policy, COOP, DNS prefetch off.
API cache control	Health-adjacent API responses are marked no-store/no-cache.
Backend-only AI	Provider calls happen server-side, not from browser code.
Input validation	Bounded schemas, sanitization, and route-specific checks.
Rate limiting	Per-IP limits on POST endpoints to reduce abuse and AI-cost drain.
Secret handling	.env.local excluded from git; production secrets expected as environment variables.
Admin access	Metrics, research logs, and review surfaces require an admin key and fail closed.
Data minimization	No required accounts or identifiers in the public demo; no ad pixels.

AI Safety Controls

- Emergency and self-harm screens run before ordinary routing.
- The language model extracts and phrases only; it does not choose care level.
- Clinical safety floors can raise acuity and are not trainable or bypassable by user text.
- Vague users trigger tailored follow-up questions instead of guesswork.
- Under-triage and forbidden outputs are release-blocking evaluation failures.
- The Recursive Experience Engine reviews weak sessions and prepares candidate training rows only after safety gates.

HIPAA, SOC 2, and ISO Readiness

The HHS HIPAA Security Rule requires safeguards for electronic protected health information across administrative, physical, and technical categories. HHS also explains that business associates handling PHI on behalf of covered entities need written agreements that limit use/disclosure and require safeguards.

Requirement before production PHI	Recommended action
Business Associate Agreements	Sign BAAs with customers and vendors that create, receive, maintain, or transmit PHI.
Risk analysis	Document risks to confidentiality, integrity, and availability of PHI.
Access control	Add authenticated accounts, MFA, role-based permissions, session timeout, and access review.
Audit controls	Persist tamper-evident logs in production infrastructure with defined retention.
Encryption at rest	Use encrypted PostgreSQL or equivalent durable storage.
Incident response	Define owner, severity levels, notification process, and breach-assessment workflow.

SOC 2 path

Carevo is not SOC 2 audited today. The practical startup path is: readiness work during pilots, SOC 2 Type I when enterprise buyers require it, and SOC 2 Type II after controls operate consistently over time. The most relevant trust-service categories are Security, Confidentiality, Availability, and Privacy.

ISO 27001 path

ISO 27001 can matter later for larger enterprise and international diligence, but it is usually not the first paid compliance step for an early U.S. healthcare startup. The SOC 2 evidence foundation should come first.

Security Questionnaire Quick Answers

Question	Answer
Do you have SOC 2?	Not yet. Carevo has started control documentation and should pursue SOC 2 Type I when buyer demand justifies it.
Are you HIPAA compliant?	Carevo is HIPAA-aware, but should not claim HIPAA compliance for PHI production use until BAAs, policies, risk analysis, access controls, and procedures are complete.
Do you sign BAAs?	Intended for covered-entity or business-associate deployments, with legal review before PHI production.
Is PHI stored?	The demo avoids required identifiers. Production PHI should use encrypted PostgreSQL or equivalent.
Is AI making the care route decision?	No. AI extracts and phrases. The deterministic routing engine chooses the care level.
Can users delete shared data?	Yes for opt-in research shares; users receive a deletion code.
Is there a formal pen test?	Not yet. Recommended before enterprise production or PHI deployment.

Open Gaps

- Do not claim HIPAA, SOC 2, or ISO 27001 certification until formal review is complete.
- Confirm BAA path for hosting, AI provider, database, and facility/location vendors.
- Move durable PHI storage to encrypted PostgreSQL with strict access controls.
- Restrict Google Maps keys by production domain and API scope.
- Complete HIPAA risk analysis, written policies, and a penetration test before enterprise PHI use.

Partner-Facing Summary

Carevo is building AI-native care-routing infrastructure for healthcare operations. The product is intentionally designed so the model does not independently choose the care level. Emergency checks, deterministic routing floors, structured provenance, consent-aware research sharing, and AuditOS monitoring give insurers and healthcare teams a clear path toward safer, auditable navigation workflows.

For an early pilot, Carevo can be evaluated as a prototype with limited or no real PHI. For production use with covered entities or business associates, Carevo should complete the required contracts, risk analysis, access controls, and evidence collection before processing PHI.

Official References

- HHS HIPAA Security Rule: <https://www.hhs.gov/hipaa/for-professionals/security/index.html>
- HHS Business Associate Contracts: <https://www.hhs.gov/hipaa/for-professionals/covered-entities/sample-business-associate-agreement-provisions/index.html>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- AICPA & CIMA SOC Suite of Services:
<https://www.aicpa-cima.com/resources/landing/system-and-organization-controls-soc-suite-of-services>

Disclaimer: This packet is an internal and partner-facing readiness document. It is not legal advice, a HIPAA determination, a SOC 2 report, an ISO 27001 certificate, or a substitute for attorney, auditor, payer, or clinical review.